CONVENIO DE PILOTO Y AUTORIZACIÓN DE SIMULACIÓN DE PHISHING

Proyecto SafeGuard (módulo PhishGuard) · Trabajo Final de Carrera · Escuela Da Vinci

1. Partes

En [ciudad], a los [día] días del mes de [mes] de 2026, se celebra este convenio entre:

- **La Organización:** [razón social], CUIT [número], con domicilio en [domicilio], representada por [nombre y cargo], quien declara tener facultades suficientes para este acto (se acreditan con [poder / estatuto / acta]).
- **El Equipo:** Lucas [apellido], Fermín [apellido] y Mauricio [apellido], estudiantes de Análisis de Sistemas de la Escuela Da Vinci, DNI [números], con domicilio en [domicilios], desarrolladores del proyecto SafeGuard (módulo PhishGuard).
- **La Institución académica:** Escuela Da Vinci, como respaldo académico del Trabajo Final de Carrera, representada por [docente o tutor]. [Confirmar con la escuela si firma o solo toma conocimiento.]

2. Antecedentes y objeto

El Equipo desarrolla PhishGuard, una plataforma de simulación de phishing para capacitar a las personas en el reconocimiento de correos fraudulentos, como parte de su Trabajo Final de Carrera.

2.1. El objeto de este convenio es que la Organización autorice un piloto sin costo y de duración limitada. En él, el Equipo ejecuta campañas de phishing simulado sobre usuarios de la Organización, con las plantillas de PhishGuard, solo para capacitar y validar la plataforma.

2.2. El piloto es de carácter académico. No genera relación laboral, societaria ni comercial entre las partes. Si la Organización quisiera contratar el servicio más adelante, se firmará un contrato aparte.

2.3. Ninguna campaña busca obtener credenciales, datos bancarios ni acceso real a los sistemas de la Organización.

3. Autorización expresa y alcance

3.1. La Organización autoriza expresamente al Equipo a enviar correos de phishing simulado a los usuarios del Anexo I, en las fechas y ventanas horarias allí indicadas. La autorización se limita a esos usuarios, fechas y plantillas.

3.2. La autoriza el representante firmante, que declara tener facultades para hacerlo y para obligar a la Organización respecto de sus sistemas de correo y de los datos de su personal. Esta autorización excluye cualquier acceso o interceptación no consentida de sistemas o comunicaciones, conforme a la Ley 26.388 de delitos informáticos.

3.3. Quedan excluidos de las simulaciones los usuarios del Anexo III, por ejemplo directivos, personas en licencia, menores de edad y cuentas compartidas o de emergencia.

3.4. Canal: solo correo electrónico. No se usan SMS, llamadas, mensajería ni redes sociales, salvo acuerdo escrito posterior.

3.5. El Equipo no hará lo siguiente:

- usar malware, adjuntos ejecutables ni enlaces que descarguen archivos;
- capturar ni guardar contraseñas o datos escritos en las páginas simuladas (si una página imita un login, descarta lo ingresado);

Rúbricas: _____ _____ _____ _____

- acceder a cuentas, sistemas o correos reales de la Organización;
- suplantar a personas reales de la Organización sin su autorización escrita;
- enviar campañas fuera del período autorizado.

3.6. Esta autorización no alcanza a otros sistemas ni a terceros ajenos a la Organización.

4. Datos personales

4.1. Las partes cumplirán la Ley 25.326 de Protección de los Datos Personales y su normativa complementaria.

4.2. Roles: la Organización es la responsable del tratamiento de los datos de su personal. El Equipo actúa como encargado y solo trata datos según sus instrucciones y para los fines de este convenio.

4.3. Datos tratados: nombre, correo corporativo, área, rol y eventos de la simulación (correo enviado, abierto, clic y reporte del mensaje como sospechoso). No se tratan datos sensibles ni contraseñas.

4.4. Finalidad: capacitación y medición agregada del riesgo de phishing. Queda prohibido usar los datos para otro fin, cederlos o venderlos.

4.5. Seguridad: los datos se alojan en [proveedor y región, por ejemplo Supabase región X], con acceso restringido al Equipo, autenticación y [cifrado en tránsito y en reposo]. [Verificar la región real. Si está fuera de Argentina, agregar una cláusula de transferencia internacional siguiendo los modelos de la AAIP.]

4.6. Conservación y borrado: los datos se guardan hasta [30] días después de terminado el piloto. Después, el Equipo los borra o los devuelve a la Organización y lo confirma por escrito.

4.7. Incidentes: si hay un acceso no autorizado a los datos, el Equipo avisa a la Organización dentro de las [48] horas de conocerlo.

4.8. Derechos: si una persona pide acceso, rectificación o supresión de sus datos, el Equipo colabora con la Organización para responder en plazo.

4.9. La Organización declara que informó o informará a su personal sobre este tratamiento de datos por sus medios internos.

5. Transparencia, ética y límites de las plantillas

5.1. Aviso general: antes del inicio, la Organización informa a su personal, por un medio interno (política de seguridad, comunicado o capacitación), que realiza simulaciones de phishing con fines educativos. No se avisa la fecha ni el contenido de cada simulación, para no distorsionar el ejercicio.

5.2. Las plantillas no pueden usar como anzuelo:

- despidos, sanciones, reestructuraciones o investigaciones internas;
- aumentos, bonos, sorteos o cualquier beneficio económico para la persona;
- salud, enfermedades, fallecimientos o emergencias familiares;
- religión, política, orientación sexual u otros datos sensibles;
- marcas reales (bancos, organismos públicos, empresas de servicios) sin su permiso: se usan marcas ficticias o genéricas.

5.3. Aprobación previa: cada plantilla figura en el Anexo II y el contacto de la Organización la aprueba por escrito antes de enviarla.

5.4. Capacitación inmediata: quien hace clic o ingresa datos ve en el momento una pantalla que explica que era una simulación y cómo reconocer las señales. Sin burlas y sin culpabilizar.

5.5. Reportar el mensaje como sospechoso es una conducta correcta y se registra como tal.

6. Resultados y no sanción

6.1. Los reportes se entregan de forma agregada, por equipo o área, con un mínimo de [5] personas por grupo para no identificar a nadie. El detalle por usuario solo lo ve [el responsable de TI o seguridad de la Organización] y se usa únicamente para capacitar.

6.2. La Organización se compromete a no usar resultados individuales para sancionar, evaluar el desempeño, despedir ni como antecedente laboral. El ejercicio busca enseñar y respeta la dignidad de las personas.

6.3. El Equipo puede usar los resultados de forma anonimizada y agregada en su trabajo final y en su presentación. La Organización [puede / no puede] ser nombrada; [elegir una opción].

6.4. Ningún documento académico identifica a personas concretas.

7. Obligaciones técnicas y operativas

7.1. Alcance real del piloto: el Anexo I detalla qué funciones de PhishGuard están operativas el día de la firma (por ejemplo envío de correos, plantillas, páginas educativas y panel de resultados) y cuáles no. [Completar con lo que realmente funciona. Si el envío real de correos todavía no está implementado, dejarlo escrito acá y definir cómo se hará la prueba.] El Equipo no promete funciones ni resultados que no estén listados.

7.2. Contacto de TI: la Organización designa a [nombre, cargo, correo y teléfono] como persona que conoce el ejercicio, para que una simulación no active un protocolo de respuesta a incidentes real.

7.3. Entregabilidad: la Organización permite (allowlist) los dominios y direcciones IP de envío del Equipo para que los correos lleguen. El Equipo los informa antes de empezar.

7.4. Pausa y cancelación: la Organización puede pedir la pausa o la cancelación inmediata de una campaña en cualquier momento, y el Equipo la ejecuta en menos de [2] horas hábiles.

7.5. Reclamos e incidentes reales: ante un reclamo de una persona o un incidente real de seguridad, las partes se avisan dentro de las [24] horas y el Equipo suspende la campaña si la Organización lo pide.

8. Responsabilidad y propiedad intelectual

8.1. Sin garantía de resultado: el Equipo no garantiza que se eviten incidentes reales ni una reducción determinada de clics. PhishGuard es un prototipo académico y se entrega tal como está.

8.2. El Equipo responde por los daños que cause con dolo o por incumplir las cláusulas 3 y 4 (autorización y datos). En los demás casos, su responsabilidad se limita a [daños directos y comprobados / monto]. [Revisar con asesoría legal: un límite de responsabilidad no libera por dolo ni por daños a terceros.]

8.3. La Organización responde por la veracidad de los datos que carga y por haber informado a su personal conforme a la cláusula 5.1.

8.4. PhishGuard, SafeGuard, su código, diseño, plantillas y documentación pertenecen al Equipo. La Organización conserva la propiedad de sus datos y de su marca. Ninguna parte recibe licencias más allá de lo necesario para el piloto.

8.5. La Organización puede dar sugerencias y el Equipo puede usarlas libremente.

9. Plazo, rescisión y confidencialidad

9.1. Plazo: desde la firma hasta el [fecha, por ejemplo 60 días después], salvo prórroga por escrito.

9.2. Rescisión: cualquiera de las partes puede terminar el convenio con aviso escrito de [5] días y sin penalidad. La Organización puede hacerlo de inmediato si el Equipo incumple las cláusulas 3, 4 o 5.

9.3. Al terminar, el Equipo deja de enviar campañas y cumple lo previsto en la cláusula 4.6.

9.4. Confidencialidad: cada parte guarda reserva de la información no pública que reciba de la otra (datos del personal, estructura de TI y resultados) durante el convenio y [2] años después. Se exceptúa la información pública y la que deba divulgarse por orden de una autoridad.

10. Disposiciones generales y firmas

10.1. Este convenio es el acuerdo completo entre las partes sobre el piloto. Cualquier cambio se hace por escrito y firmado por todas.

10.2. Si una cláusula resulta inválida, el resto sigue vigente.

10.3. Ley aplicable: la de la República Argentina. Las partes intentarán resolver cualquier conflicto de buena fe y, si no pueden, se someten a los tribunales ordinarios de [jurisdicción], con renuncia a cualquier otro fuero. [Revisar con la escuela.]

10.4. Las notificaciones se hacen por correo electrónico a las direcciones indicadas junto a cada firma y valen desde que se envían.

Rúbricas: _____ _____ _____ _____

Se firman [tres] ejemplares de un mismo tenor, en el lugar y fecha que se indican a continuación.

Lugar:_____ Fecha:_____

LA ORGANIZACIÓN
[razón social]

_____
Firma

Aclaración:_____

DNI / CUIT:_____

Cargo:_____

Correo:_____

EL EQUIPO
Lucas [apellido]

_____
Firma

Aclaración:_____

DNI / CUIT:_____

Cargo:_____

Correo:_____

EL EQUIPO
Fermín [apellido]

_____
Firma

Aclaración:_____

DNI / CUIT:_____

Cargo:_____

Correo:_____

EL EQUIPO
Mauricio [apellido]

_____
Firma

Aclaración:_____

DNI / CUIT:_____

Cargo:_____

Correo:_____

ESCUELA DA VINCI
(si firma) [docente o tutor]

_____
Firma

Aclaración:_____

DNI / CUIT:_____

Cargo:_____

Correo:_____

Rúbricas:_____ _____ _____ _____

Anexos

Anexo I. Alcance de la campaña

Dato	Detalle
Período autorizado	[desde – hasta]
Días y ventanas horarias	[días y horas]
Cantidad de usuarios	[número]
Cantidad de campañas	[número]
Funciones de PhishGuard operativas	[lista]
Funciones que no están operativas	[lista]
Dominios e IP de envío	[los informa el Equipo]

Conformidad (rúbrica). Organización:_____ Equipo:_____

Anexo II. Plantillas aprobadas

N.º	Nombre	Pretexto	Marca usada	Aprobada por	Fecha
1	[ ]	[ ]	[ficticia / genérica]	[ ]	[ ]
2	[ ]	[ ]	[ficticia / genérica]	[ ]	[ ]
3					
4					
5					

Conformidad (rúbrica). Organización:_____ Equipo:_____

Anexo III. Usuarios excluidos

Usuario o cargo	Motivo
[ ]	[directivo / licencia / menor de edad / cuenta compartida]

Conformidad (rúbrica). Organización:_____ Equipo:_____

Rúbricas:_____ _____ _____ _____